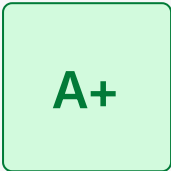


HTTP Observatory Report

 Report Feedback

Scan summary: vaultkeepr.xyz



Score: 115 / 100
Scan Time: 3 minutes ago
Tests Passed: 12 / 12

Scan results

Scoring

Test	Score	Reason	Recommendation
<u>Content Security Policy (CSP)</u>	0	Content Security Policy (CSP) implemented with unsafe sources inside style-src. This includes 'unsafe-inline', data: or overly broad sources such as https. 'form-action' is set to 'self', 'none' or 'specific source'	Lock down style-src directive, remove 'unsafe-inline', data: and broad sources
<u>Cookies</u>	-	No cookies detected	None
<u>Cross Origin Resource Sharing (CORS)</u>	0	Content is not visible via cross-origin resource sharing (CORS) files or headers.	None
<u>Redirection</u>	0	Initial redirection is to HTTPS on same host, final destination is HTTPS	None
<u>Referrer Policy</u>	+5	Referrer-Policy header set to no-referrer, same-origin, strict-origin or strict-origin-when-cross-origin.	None
<u>Strict Transport Security (HSTS)</u>	0	Strict-Transport-Security header set to a minimum of six months (15768000).	Consider preloading: this requires preload and includeSubDomains and setting max-age to at least 315 year), and submitting your site to https://hstspreload.org/ .

Test	Score	Reason	Recommendation
<u>Subresource Integrity</u>	+5	Subresource Integrity (SRI) is implemented and all scripts are loaded securely.	None
<u>X-Content-Type-Options</u>	0	X-Content-Type-Options header set to nosniff .	None
<u>X-Frame-Options</u>	+5	X-Frame-Options (XFO) implemented via the CSP frame-ancestors directive.	None
<u>Cross Origin Embedder Policy</u>	0	Cross-Origin-Embedder-Policy header not implemented.	Set to require-corp or credentialless
<u>Cross Origin Opener Policy</u>	0	Cross-Origin-Opener-Policy header not implemented.	Set to same-origin , same-origin-all-popups , or noopener-allow-popup
<u>Cross Origin Resource Policy</u>	-	Cross Origin Resource Policy (CORP) is not implemented (defaults to cross-origin).	None

CSP analysis

- Content Security Policy (CSP) implemented with unsafe sources inside style-src. This includes '**unsafe-inline**', **data:** or overly broad sources such as **https**. '**form-action**' is set to '**self**', '**none**' or '**specific source**'

Test	Result	Info
Blocks execution of inline JavaScript by not allowing ' unsafe-inline ' inside script-src		Blocking the execution of inline JavaScript provide strongest protection against cross-site scripting at Moving JavaScript to external files can also help r site more maintainable.
Blocks execution of JavaScript's eval() function by not allowing ' unsafe-eval ' inside script-src		Blocking the use of JavaScript's eval() function ca prevent the execution of untrusted code.
Blocks execution of plug-ins, using object-src restrictions		Blocking the execution of plug-ins via object-src 'r inherited from default-src can prevent attackers fr loading Flash or Java in the context of your page.
Blocks inline styles by not allowing ' unsafe-inline ' inside style-src		Blocking inline styles can help prevent attackers fr modifying the contents or appearance of your pag styles to external stylesheets can also help make ; more maintainable.
Blocks loading of active content over HTTP or FTP		Loading JavaScript or plugins can allow a man-in-middle to execute arbitrary code or your website. I

Test	Result	Info
		your policy and changing links to HTTPS can help this.
Blocks loading of passive content over HTTP or FTP	✓	This site's Content Security Policy allows the load passive content such as images or videos over ins protocols such as HTTP or FTP. Consider changin load them over HTTPS.
Clickjacking protection, using frame-ancestors	✓	The use of CSP's frame-ancestors directive offers grained control over who can frame your site.
Deny by default, using default-src 'none'	✗	Denying by default using default-src 'none' can ens your Content Security Policy doesn't allow the loa resources you didn't intend to allow.
Restricts use of the <base> tag by using base-uri 'none' , base-uri 'self' , or specific origins.	✓	The <base> tag can be used to trick your site into scripts from untrusted origins.
Restricts where <form> contents may be submitted by using form-action 'none' , form-action 'self' , or specific URIs	✓	Malicious JavaScript or content injection could mc where sensitive form data is submitted to or create additional forms for data exfiltration.
Uses CSP3's 'strict-dynamic' directive to allow dynamic script loading (optional)	-	'strict-dynamic' lets you use a JavaScript shim loa all your site's JavaScript dynamically, without havi track script-src origins.

Cookies

No cookies detected

Raw server headers

Header	Value
Nel	{"report_to":"cf-nel","success_fraction":0.0,"max_age":604800}
Date	Sun, 06 Sep 2026 14:04:42 GMT
Link	</_next/static/media/13971731025ec697-s.p.woff2>; rel=preload; as="font"; crossorigin=""; nonce="20v6J1ZvfyYK25Ixc1sIfw=="; type="font/woff2"
Vary	RSC, Next-Router-State-Tree, Next-Router-Prefetch, Next-Router-Segment-Prefetch, Accept-Encoding
Cf-Ray	a36e0638efa775c2-SEA

Header	Value
Server	cloudflare
Alt-Svc	h3=":443"; ma=86400
Report-To	{"group":"cf-nel","max_age":604800,"endpoints": [{"url":"https://a.nel.cloudflare.com/report/v4? s=SVsEe2nfcM0FmNJ7%2FAWU8%2BGB9%2B203khtgV1wPjYrzFEe09kQfUM 2FtdS3nVsUdRCzT%2BHu3EM0EoFnmkNT%2BuCe1i%2Ffk1JFeZIAaPaHjxrKix s6r8ZWew%3D%3D"}]}
Connection	close
X-Served-By	vaultkeepr.xyz
Content-Type	text/html; charset=utf-8
Cache-Control	public, max-age=0, s-maxage=3600, stale-while-revalidate=86400
Server-Timing	cfCacheStatus;desc="DYNAMIC", cfEdge;dur=15,cfOrigin;dur=594
Cf-Cache-Status	DYNAMIC
Referrer-Policy	strict-origin-when-cross-origin
X-Frame-Options	DENY
Transfer-Encoding	chunked
Permissions-Policy	camera=(), microphone=(), geolocation=(), interest-cohort=()
X-Content-Type-Options	nosniff
Content-Security-Policy	default-src 'self'; script-src 'self' 'nonce-20v6J1ZvfYK25Ixc1sIfw==' 'wasm- eval'; style-src 'self' 'unsafe-inline' https://fonts.googleapis.com; img-src 'self' https://blob:; font-src 'self' data: https://fonts.gstatic.com; connect-src 'self' http blob:; frame-src 'self' https:; object-src 'none'; base-uri 'self'; form-action 'self' ancestors 'none'
Strict-Transport-Security	max-age=31536000; includeSubDomains; preload

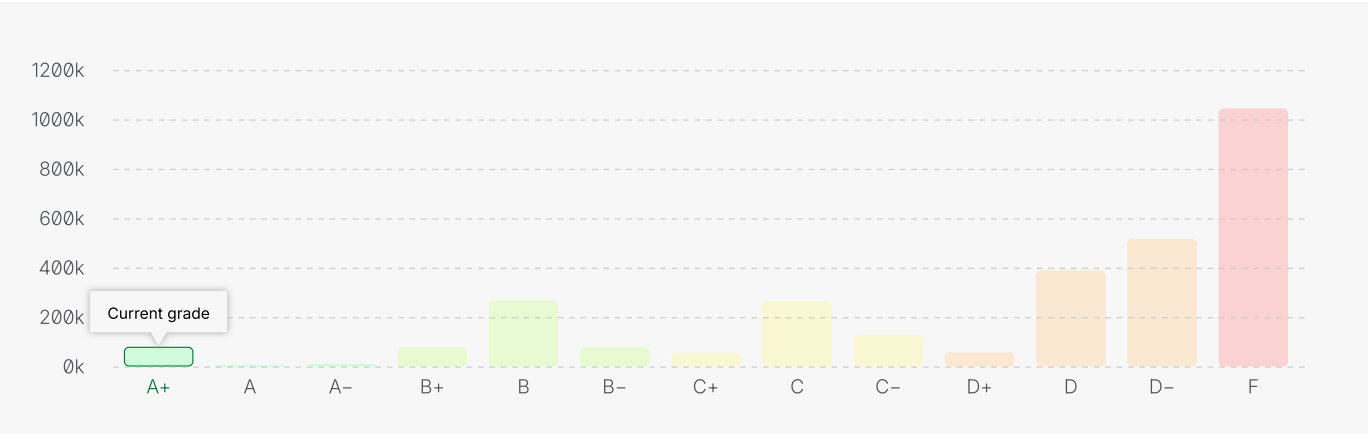
Scan history

Changes in score over time

Date	Score	Grade
6 sept. 2026, 16:04:41	115	A+

Benchmark comparison

Performance trends from the past year



Refer to this graph to assess the website's current status. By following the recommendations provided and rescanning, you can expect an improvement in the website's grade.



Your blueprint for a better internet.